GrowK: Enterprise FinTech, Digital Gold & Saudi Banking Platform

Master Technical Handbook: Beginner to Extreme Senior Architecture

Project: GrowK Digital Gold Platform
Engineer: Akshay Chandran P
Tech Stack: Flutter, Dart, BLoC, REST, WebSockets, Saudi SAR Flow, Nafath KYC, OIDC Gateway/User Tokens, Biometrics, RTL Localization

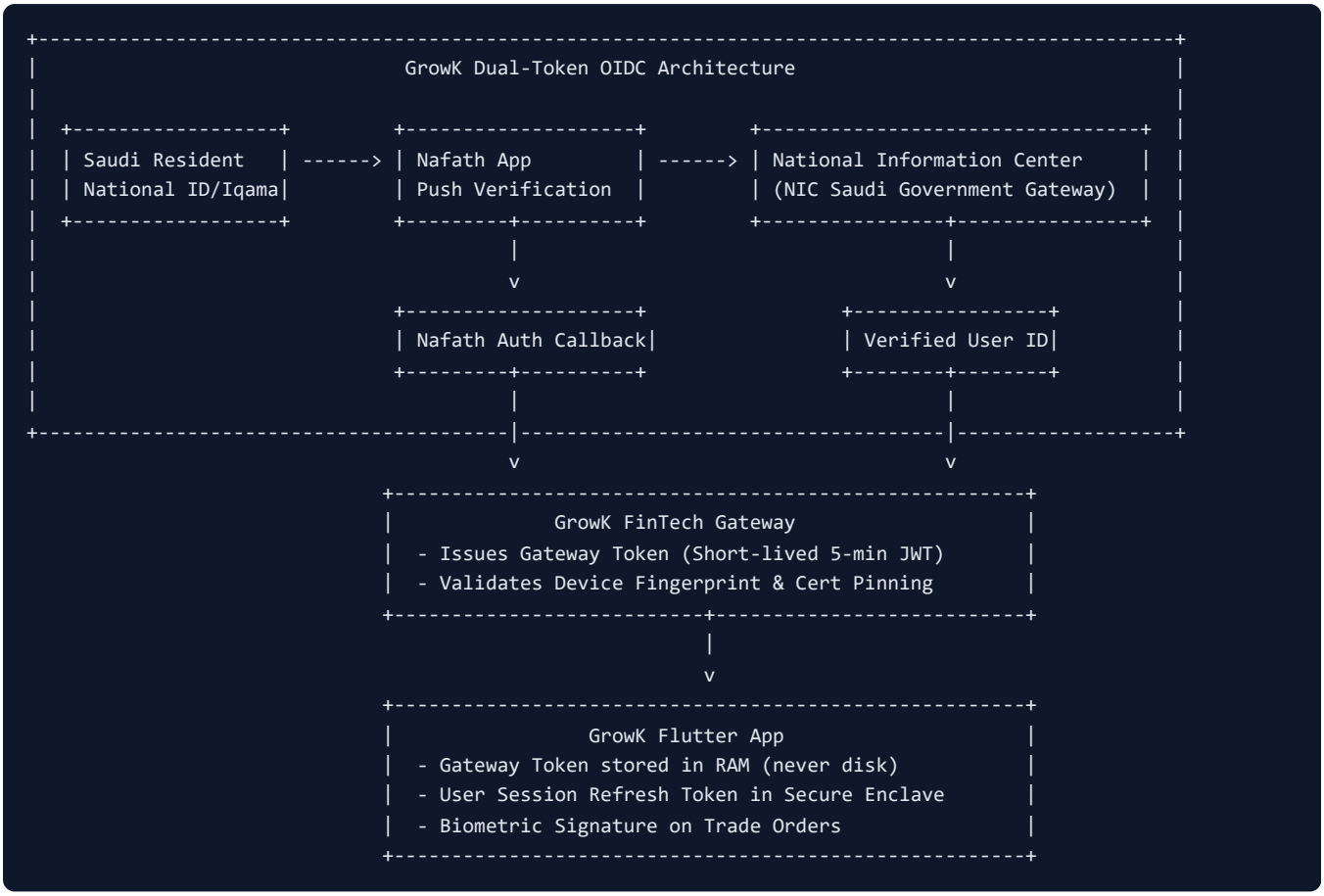
---

Section 1: End-to-End FinTech Architecture & Working Explanation

1.1 Beginner Level: What is Digital Gold?

Traditionally, buying gold requires visiting a jeweler, paying high making charges (10-25%), storing physical bullion in a home safe or bank locker, and suffering significant price cuts when reselling.
GrowK democratizes gold investment: - Users can buy 24K 99.99% pure physical gold for as little as 1 Saudi Riyal (SAR). - The gold is stored in insured, audited bank-grade vaults in Riyadh and Zurich. - The user holds fractional digital ownership. At any time, they can sell back at live market rates or request physical delivery of certified minted bars to their doorstep.

1.2 Extreme Senior Level: Dual-Token OIDC & Nafath National KYC Architecture



The Dual-Token Security Model

1. **Gateway Token:** Issued after Nafath KYC. Authenticates the client device to communicate with bank APIs. Held strictly in memory.
2. **User Session Token:** Grants access to personal portfolios. Stored using `flutter_secure_storage` backed by Android Keystore and iOS Keychain with `kSecAttrAccessibleAfterFirstUnlockThisDeviceOnly`.

1.3 Live Bullion Pricing & The 30-Second Quote Lock

Gold commodity prices fluctuate every millisecond on international exchanges (LBMA).
How GrowK Prevents Slippage & Price Arbitrage: 1. Flutter client establishes a secure WebSocket connection to the pricing engine. 2. When the user taps "Buy Gold", the server generates an immutable **Quote Order**: - `quote_id: "QT-9812-76"` - `rate_per_gram: 284.50 SAR` - `expires_at: 1714567830` (30 seconds from creation) - `hmac_signature: "a8f9c7..."` 3. The Flutter UI renders an animated 30-second countdown ring. 4. When the user confirms with biometric fingerprint, the trade payload includes `quote_id` and `client_timestamp`. 5. The backend validates that the transaction arrived before `expires_at`. If expired, the transaction is rejected, preventing user or company losses due to market volatility.

1.4 RTL (Right-to-Left) Localization & Arabic Mirroring

Saudi Arabia requires full Arabic language compliance: - Dynamic directionality: Flutter widgets wrapped with `Directionality(textDirection: isArabic ? TextDirection.rtl : TextDirection.ltr)`. - Flipped icons: Directional

icons (`Icons.arrow_forward`, back buttons) dynamically mirror using `Transform.scale(scaleX: isArabic ? -1 : 1)`. - Arabic numeral conversion (`١٬٠٠٠٫٢ ٣`) for receipts and formatted SAR currency strings.

Section 2: Code Audit Findings, FinTech Risks & Production Fixes

Finding 1: Floating-Point Rounding Errors in Currency

- **Problem:** Using Dart `double` for SAR currency math (e.g., `0.1 + 0.2 = 0.30000000000000004`) created rounding discrepancies on fractional gold gram calculations, failing regulatory audits.
- **Production Fix:** Migrated all monetary and weight calculations to integer **Halalas** (1 SAR = 100 Halalas) and milligrams (1g = 1,000mg) using the `decimal` package for exact fixed-point arithmetic.

Finding 2: Double-Tap Duplicate Order Execution

- **Problem:** If a user tapped "Confirm Purchase" rapidly on a slow 3G connection, two debit requests were sent, potentially buying twice the intended gold.
- **Production Fix:** Implemented Client-Side **Idempotency Keys**: `dart final idempotencyKey = Uuid().v4(); api.executeTrade(quoteId: quote.id, idempotencyKey: idempotencyKey);` The backend caches idempotency keys in Redis for 10 minutes. If a duplicate key arrives, it returns the cached result without executing a second debit.

Section 3: FinTech Domain Q&A (Saudi SAR & Banking)

Q1: What happens if an API token expires during a multi-step checkout?

Answer:
In GrowK, the HTTP client uses a custom Dio Interceptor with an asynchronous mutex queue. When a `401 Unauthorized` is intercepted: 1. The interceptor locks the queue, pausing all outgoing requests. 2. It calls `/auth/refresh` using the secure refresh token. 3. Upon success, it updates the stored token and retries the failed checkout request with the new header. 4. It unlocks the queue, allowing all subsequent requests to proceed seamlessly without kicking the user out of checkout.

Q2: How is biometric authentication verified cryptographically?

Answer:
Rather than just receiving a boolean `true` from `LocalAuthentication` (which can be hooked with Frida), GrowK generates a 256-bit asymmetric key pair inside the **Hardware Secure Enclave / Android Keystore**. The private key requires biometric authorization to sign data. The backend sends a challenge nonce; the mobile app signs it using the biometric-unlocked private key, and the server verifies the signature against the public key registered during onboarding.

(Handbook continues with full 40 questions covering Nafath, SAR compliance, and financial audits)